

Module 7: Auditing Basics and Auditor Assumptions

Key components typically include:

1. Understanding Auditing Basics
 - a. Purpose of Audits: Clarifies why audits are conducted, emphasizing objective assessment, accountability, and improvement of the ISMS (Information Security Management System).
 - b. Types of Audits: Explores different audit types (internal, external, compliance) and how each fits into ISO 27001.
 - c. Stages of an Audit: Overview of planning, conducting, reporting, and follow-up stages within an ISO 27001 audit.
2. Principles of Auditing
 - d. Integrity: The importance of maintaining honesty, impartiality, and professionalism throughout the audit.
 - e. Evidence-Based Approach: How to ensure audit findings are based on sufficient, relevant, and reliable evidence.
 - f. Confidentiality: Ensuring that all audit findings and information are kept secure and only shared with relevant stakeholders.
3. Auditor Assumptions
 - g. Neutrality: Auditors must assume a neutral stance and avoid bias, entering the audit without preconceived notions about the organization's ISMS effectiveness.
 - h. Focus on Risk and Compliance: Auditors should assume that their main role is to verify compliance and assess risks, not to find fault unnecessarily.
 - i. Open-mindedness: The importance of being open to new information and understanding the organization's unique context and objectives.
4. Practical Guidelines for Auditors
 - j. Effective Questioning: Techniques for asking open-ended questions that gather the necessary information without leading the auditee.
 - k. Observation Skills: Tips on how to observe processes and interactions objectively to identify both strengths and weaknesses.
 - l. Documentation Review: Approaches for reviewing policies, procedures, and other documents to evaluate alignment with ISO 27001 standards.
5. Case Studies and Examples
 - m. Often, the module includes case studies to provide examples of common assumptions auditors might make and how to handle these effectively to ensure a fair and objective audit.

Techniques for Finding Evidence in an ISO 27001 Audit

As an auditor, the goal is to find concrete evidence—not to guess. There are three primary methods for collecting evidence:

1. Review Documents and Records

- a. Purpose: Documents and records offer the most reliable proof (“hard evidence”).
- b. Method: Ask employees to provide documents and records relevant to the audit area.
- c. Example: To assess training, request the “Training Procedure” document and “Training Records” as proof.
- d. Note: Not all documents are mandatory, but records are often available and can confirm compliance.

2. Interview Employees

- e. Purpose: Interviews validate processes when documents or records are unavailable or insufficient.
- f. Method: Interview several employees involved in the same process to check for consistency.
- g. Example: To verify the electronic disposal process, ask multiple employees involved if they follow the same steps. Consistency indicates a well-defined process; variations may indicate a lack of training or defined procedures.

3. Observe Activities and Facilities

- h. Purpose: Observing processes or facilities gives visual confirmation of compliance with procedures.
- i. Method: Visit relevant locations, such as server rooms, to observe how procedures are carried out.
- j. Example: To confirm physical access control to the server room, check if the security measures match the procedure and align with employee statements.

Sampling Records During an ISO 27001 Audit

When conducting an audit, sampling employee records is crucial for efficiency and effectiveness. Here are key points to consider:

1. Determine the Sample Size

- a. Small Workforce: If a company has a limited number of employees (e.g., 20), review all training records for a comprehensive assessment.
- b. Large Workforce: For larger organizations (e.g., thousands of employees), it’s impractical to check every record.

2. Focus on Relevant Records

- c. Critical Areas: Concentrate on records most likely to reveal non-conformities, particularly those that are critical to compliance.
- d. Example: If personal data handling is a key concern, prioritize training records of employees who manage such data.

3. Prioritize New Employees

- e. Training Gaps: New employees may be more susceptible to insufficient training compared to long-term staff. Review their records to identify potential training deficiencies.

4. Maintain Control Over Record Selection

- f. Auditor's Decision: Do not rely on the organization being audited (ODT) to choose which records to present. The auditor should independently determine which records to review based on relevance and risk.

Effective Interviewing Techniques for Evidence Gathering in ISO 27001 Audits

Interviewing is a key method for gathering evidence in an audit, though it can be challenging. Here are essential techniques to enhance your effectiveness during interviews:

1. Use Open-Ended Questions

- a. Encourage Discussion: Open-ended questions prompt detailed responses and insights into operations.
- b. Examples:
 - c. "Please describe how you manage access control to your IT system."
 - d. "Can you explain how you decide which trainings should be provided to new employees?"
- e. Best Question: "Please describe what you do in the company." This often uncovers valuable information about processes and potential non-conformities.

2. Avoid Closed-Ended Questions

- f. Limitations: Closed-ended questions yield yes/no answers and do not facilitate deeper understanding.
- g. Examples: "Is your job title office manager?" or "Is this the room where you store electronic waste?"
- h. Exceptions: Use closed-ended questions to confirm specific pieces of evidence, e.g., "Did you send employee XYZ for training on personal data protection?"

3. Identify Root Causes of Non-Conformities

- i. 5-Why Technique: This technique helps uncover the root cause by asking "why" multiple times—typically five.
- j. Example Process:
 - k. Initial Non-Conformity: New employees weren't trained on personal data protection.
 - l. First Question: "Why weren't they sent for training?" (Response: "We didn't know they would handle personal data.")
 - m. Continue asking why to trace back to the underlying issue (e.g., lack of a checklist).
 - n. Outcome: This approach leads to identifying systemic issues that need addressing.

4. Importance of Communication Skills

- o. Effective Feedback: An auditor must provide meaningful feedback during interviews to clarify issues and promote discussion.
- p. Engagement: Good communication fosters a comfortable environment, encouraging employees to share information openly.

Audit Findings: Understanding Non-Conformities and Observations

Internal audits result in two primary outcomes known as audit findings: non-conformities and observations. Here's a breakdown of each:

1. Non-Conformities

- a. Definition: Evidence or hard proof that the organization is not compliant with:
- b. Internal documents (e.g., policies and procedures)
- c. Relevant standards (e.g., ISO 27001)
- d. Implication: Indicates a failure to meet established criteria, requiring corrective action.

2. Observations

- e. Definition: Comments made by the auditor that can be either positive or negative, based on their assessment.

Types:

- f. Positive Observations: Highlighting practices that are effective and should be recognized as good examples for other areas of the organization.
- g. Negative Observations: Noting areas for improvement where the auditor suspects non-compliance but lacks sufficient evidence to classify it as a non-conformity.

Recording Audit Findings

- h. Internal Audit Report: Both non-conformities and observations must be documented in the audit report.
- i. Focus: Auditors should concentrate solely on identifying non-conformities or providing observations—no additional outcomes are necessary.

Definition of Non-Conformity in ISO 27001

Non-conformity refers to the failure to fulfill a specific requirement. In the context of ISO 27001, there are four main types of requirements that can lead to a non-conformity:

- 1. ISO 27001 Standard Requirements:
 - a. Example: Failing to perform a risk assessment or lacking an information security policy.
- 2. Legislative Requirements:
 - b. Example: Non-compliance with data protection laws or regulations related to cryptography and electronic services.
- 3. Internal Information Security Policies and Procedures:
 - c. Example: Not following the backup procedure defined by the company (e.g., backing up every 24 hours instead of every six hours).
- 4. Requirements from Interested Parties:
 - d. Example: Failing to meet service delivery timelines stipulated in agreements with partners or clients.

Key Points

- e. Raising Non-Conformities: Internal auditors must identify non-conformities when there is a failure to comply with any of the above requirements.
- f. Requirement Necessity: A non-conformity can only be raised if a specific requirement exists. For example, an auditor cannot claim a non-conformity based on personal beliefs (e.g., a preferred distance between sites) if there is no formal requirement for that distance.

Observations in Internal Audits

Observations play a crucial role in internal audits by identifying areas for improvement and highlighting positive practices. Here are the key points:

1. Improvement Suggestions:

- a. Observations can be used to recommend enhancements to existing procedures.
- b. Example: If a backup procedure states that backups are performed once a day, but the auditor believes they should occur more frequently, this suggestion can be recorded as an observation.

2. Highlighting Positive Practices:

- c. Observations can also recognize departments excelling in specific activities.
- d. Example: If one department excels in security awareness training, the auditor can document this success to encourage other departments to adopt similar practices.

Key Points

- e. Observations are useful for both suggesting improvements and recognizing effective practices within the organization.
- f. Documenting observations can lead to enhanced compliance and performance across departments.

Internal vs. External Audit

Understanding the distinctions between internal and external audits is crucial for effective compliance and management. Here are the key points:

1. Definition

- a. Internal Audit: Conducted by employees of the organization to assess and improve its own processes.
- b. External Audit: Performed by a third party, often a certification body, to evaluate compliance with standards.

2. Purpose

- c. Internal Audit: Aims to enhance the information security management system (ISMS) within the company.

- d. External Audit: Seeks to determine if the organization meets the specified standards, leading to certification.

3. Use of Results

- e. Internal Audit: Results are used solely within the organization for internal improvements.
- f. External Audit: Results can be publicly shared, especially if the audit leads to certification, which results in a public document.

Key Points

- g. Certification Audit: A common type of external audit that assesses compliance with ISO standards and can lead to a public certificate.
- h. The main difference lies in the audit's purpose, audience, and how the results are utilized.

Annual Audit Program for ISO 27001

Creating an effective annual audit program for ISO 27001 involves several critical elements. Here are the key points to include:

1. Audit Period

- a. Define the duration of the program, typically one year, but it can extend up to three years.

2. Scheduling Individual Audits

- b. Specify the timing for each audit.
- c. For a small company (e.g., 20 employees), plan one comprehensive audit annually.
- d. For larger organizations (e.g., 10 business units), schedule separate audits for each unit.

3. Scope of the Audit

- e. Define the scope by considering locations and processes.
- f. Focus on significant processes that are more likely to present non-conformities.

4. Audit Criteria

- g. Include relevant criteria such as:
 - h. ISO 27001 standard
 - i. Legal and regulatory requirements
 - j. Internal ISMS documentation
 - k. Third-party requirements from partners and customers

5. Audit Methods

- l. Specify the methods for conducting audits:
 - m. Reviewing documentation and records
 - n. Personal observations
 - o. Employee interviews

6. Auditor Assignment

- p. Identify who will perform the internal audits.
- q. This could be a single auditor or a team, with a designated team leader.

7. Focus on High-Risk Areas

- r. Plan audits in areas with the highest potential for non-conformities.
Example focus areas:
- s. IT department for technical controls
- t. Departments handling sensitive customer data
- u. Departments with a history of previous non-conformities

8. Information Security and Confidentiality

- a. Ensure the audit program addresses the need to maintain the confidentiality of information collected during audits.

9. Legal Compliance

- b. Include checks for compliance with legal requirements during internal audits.

10. Associated Audit Risks

- c. Identify potential risks associated with the audit process.
- d. Key Points
- e. The audit program should be comprehensive and structured to improve the Information Security Management System (ISMS).
- f. Emphasis should be placed on high-risk areas to ensure compliance and enhance security practices.

Audit Plan for an Individual Audit (ISO 27001)

An audit plan for an individual ISO 27001 audit provides a structured approach to conduct an effective audit. Though ISO 27001 does not mandate a specific format, the plan typically includes the following elements:

1. Audit Elements

- a. Define the focus areas for the audit. Options include:
- b. Processes within the company
- c. Departments within the company
- d. ISO 27001 Clauses (e.g., clause-by-clause auditing)
- e. For clause-by-clause audits, you might start with clauses like:
- f. Clause 4 - Context of the organization, internal/external parties, ISMS scope, etc.

2. Timing and Schedule

- g. Outline the audit schedule by specifying times for each department or area.
Example: Start with the HR department at 9:00 AM, then audit the production facility at 11:00 AM.
- h. Allocate sufficient time for each area to ensure thorough review.

3. Contact Persons

- i. Identify the contact persons for each department involved.
- j. Inform them in advance to allow them to prepare and adjust their schedules.

4. Audit Team Roles

- k. Specify responsibilities if there is more than one auditor.
- l. Example: Assign one auditor to Department A and another to Department B.

5. Audit Objectives, Scope, and Criteria

- m. Include relevant information from the audit program, such as:
- n. Audit Objectives - What the audit aims to achieve
- o. Audit Scope - Areas and processes covered
- p. Audit Criteria - Standards, policies, and legal requirements used as a benchmark

6. Consideration of Audit Impacts

- q. Assess potential effects of audit activities on business processes.
Example: Avoid contamination risks in cleanroom facilities.
- r. Ensure the plan is practical, allowing for adequate time and resources.

Key Points

- s. Purpose: The audit plan provides a roadmap for conducting a specific ISO 27001 audit, tailored to the organization and audit scope.
- t. Flexibility: Not mandatory but highly useful, especially for first-time or complex audits.
- u. Focus: The plan should be realistic and based on objectives, scope, and criteria, without needing specific audit questions (these belong in the internal audit checklist).

Creation of the Internal Audit Checklist

The internal audit checklist is a key tool that helps guide auditors through complex audits by organizing requirements, policies, and procedures that need verification.

Purpose

- a. Serves as a memory aid for the auditor to track clauses, records, policies, and procedures during the audit.
- b. Helps ensure that key requirements are reviewed, such as compliance with policies (e.g., clear desk and screen policies).

Development Process

- c. Document Review: As you review the company's documentation, list out all rules and records that need to be verified.
Example: If a policy states screens should auto-lock after five minutes, add this to the checklist for verification.

Checklist Structure

The checklist is typically a 4-column document:

1. Clause Number: Refers to the standard clause for easy tracking.
2. Description: Details what to look for (e.g., clear desk policy compliance).
3. Compliance Status: Mark if the requirement is met (Yes/No).

4. Notes: Add observations or additional findings.
- d. The first two columns are prepared during checklist creation, while the third and fourth are used during the audit for real-time findings.

Flexibility in Use

- e. The checklist is a guideline, not a strict rule. Be open to following new leads that emerge during interviews or observations.
- f. Focus on Requirements: Include only requirements related to the specific processes being audited.

Internal Audit Report

ISO 27001 requires a written Internal Audit Report as a mandatory document for communicating audit findings to top management and other stakeholders. This ensures details are clearly documented and preserved for future reference.

Key Elements of the Internal Audit Report

1. General Information:
 - a. Dates of Audit: Specify when the audit was performed.
 - b. Auditor Details: List who conducted the audit.
 - c. Scope & Criteria: Define the audit's scope and the criteria used for evaluation.
2. Non-Conformities:
 - d. Describe any non-conformities found, detailing areas of non-compliance.
3. Observations:
 - e. Summarize observations, including both positive points and suggestions for improvement.

Distribution

- f. The audit report should be issued and distributed according to the guidelines in the Internal Audit Plan or Internal Audit Procedure.

Corrective Action Follow-up

Following up on corrective actions is essential to ensure that non-conformities are fully resolved. Here's how the follow-up process should be handled:

Key Steps for Corrective Action Follow-up

1. Corrective Action Request Form:
 - a. The resolution of non-conformities should be documented by the responsible team through a Corrective Action Request Form.
 - b. This form tracks the steps taken to address and resolve the issue.
2. Verification:

- c. Conduct On-site Checks: Visit the department to confirm that:
 - d. The non-conformity has been resolved.
 - e. The root cause of the non-conformity has been removed to prevent recurrence.
3. Mini-Audits for Follow-up:
- f. After the main audit, mini-audits may be conducted specifically to verify the resolution of outstanding non-conformities.

Recording the Evidence in Internal Audits

Accurate evidence recording is essential to support the findings in the Internal Audit Report. Here's how to effectively document evidence during an internal audit:

Key Elements for Recording Evidence

1. Documents: Record the name, version number, and date of publishing for each document reviewed.
2. Records: Write down the exact name of the record, along with its date and serial number.
3. Interviews: Note the name of the interviewee, job title, date and time, and any relevant quotes.
4. Facility and Process Observations: Document the location (specific rooms), date and time, and a description of observations.
5. Internal Audit Checklist: Use a checklist with space for each item to note findings alongside items being checked.

Best Practices

- a. Accuracy: Record detailed evidence to allow future retrieval.
- b. Retention: Keep evidence records securely, as they may be needed months or years after the audit.

Audio or video recordings, document copying, and requesting written statements are not commonly used for evidence recording.